

Master-Abschlussbericht — Phase 5

24.08.2026 / 20:00 · Delta-Check beider Repos · GO/NO-GO
Vorgänger: Phase 4.5 (24.08. / 14:00, Commit 58931d2)

Belegstufen: IMPLEMENTIERT = Code im Repo · GETESTET = Test grün · CI-GRÜN = Actions-Lauf auf genau diesem Commit success · DEPLOYED = auf main · LIVE_VERIFIZIERT = gegen Produktions-DB oder Live-API gemessen · EXTERN_BLOCKIERT = nur Yusuf lösbar.

1 · Ausgangsstand und Änderung

Phase 4.5 endete bei Alltagsengel 45f7364 / ChairMatch 6776def, vitest 4498 + test:unit 794 + ChairMatch 487, und liess vier Punkte offen: 28 Module ohne Tests (P1), CAMT nie produktiv gelaufen (P1), tsconfig schloss hooks/** aus (P2), 58 Env-Variablen ohne Validierung (P2). Phase 5 hat die beiden P2 geschlossen.

Commit	Repo	Inhalt
6013ba0	AE	P0-Blocker, zentrale ENV-Validierung (lib/env/, 1011 Z.), instrumentation-Hook, tsconfig-Ausschluss hooks/** entfernt
6049fd7	AE	Cron-Bearer fail-closed + Konstantzeit (9 Stellen), DTA-Upload-Traversal, DATEV-CSV-Escaping, CAMT-Größenriegel
78e94b1	AE	Security-Befundbericht docs/SECURITY_DELTA_PHASE5_2026-08-24.md
2c834cc	AE	CAMT-Produktionsreife (App-Dubletten Sperre + Migration), Mahnversand-Route, 3 PGLite-E2E-Suiten (1981 Z.)
30622cd	CM	CI-Workflow ERSTMALS angelegt, Preis-/Compliance-Schema-Analyse + Migration, Legacy-Cleanup
1706c5d	CM	actions/checkout + setup-node auf v5 (Node-20-Deprecation)

2 · Prüfstand — alle Läufe dieser Session

Prüfung	Alltagsengel	ChairMatch
npx tsc --noEmit	Exit 0 · 0 Fehler	Exit 0 · 0 Fehler
npx vitest run	4827 grün / 38 skipped · Exit 0	487 grün · Exit 0
npm run test:unit (node:test)	800 / 800 · 10 Suiten · Exit 0	—
npm run lint:forbidden	24471 Dateien · 0 Treffer · Exit 0	—
GitHub Actions CI (HEAD)	success · 2c834cc	success · 1706c5d
Live-Check	health 200 · version=2c834cc=HEAD · 5/5 pass	www 200 · Apex 308 · schema-probe Exit 0
Arbeitsbaum	sauber · 0 uncommitted	STATUS.md (auto-generiert)

Tests gesamt 6114 grün (Phase 4.5: 5779), 0 rot — Delta +335. Rot ist nichts. Die beiden CI-Läufe vor HEAD stehen auf cancelled: vom nächsten Push abgelöst, nicht fehlgeschlagen.

3 · Live gemessen (Produktions-DB und API)

Sicherheit	Wert	Datenbestand	Wert
RLS auf public-Tabellen	308 / 308 aktiv	organizations / clients	6 / 4
anon-Schreibrechte	0	bookings / service_records	10 / 30
org_fence-Policies	244, alle RESTRICTIVE	invoices / payments	3 / 0
SECDEF für anon ausführbar	0	camt_imports / zahlungseingaenge	0 / 0
Storage-Buckets public	0 von 13	invoice_email_log / notif.-log	0 / 0

Das ist der entscheidende Zahlenblock: die Geldpfade sind gebaut, geprüft und ausgerollt — aber leer. Kein Zahlungseingang, kein CAMT-Import, keine protokollierte Zustellung.

4 · Migrationen (Delta-Umfang, live nachgeprüft)

Geprüft wurde die in Phase 5 hinzugekommene Migration plus die vier aus Phase 4.5. Ein Vollabgleich aller 356 Migrationsdateien war nicht Teil dieses Laufs und wird hier nicht behauptet.

Migration	Live-Beleg	Status
AE 20261001000000 mahnqueue_retry_dead_letter	versuche / letzter_versuch_am / naechster_versuch_ab, Status aufgegeben, 2 Indexe	LIVE
AE 20261001010000 vpkzp_mandantenpaarung	Trigger trg_vpkzp_mandantenpaarung vorhanden	LIVE
AE 20261002000000 least_privilege_delta	anon-Schreibrechte = 0	LIVE
AE 20261002000002 billing_landesregeln_fence	Policy org_fence_billing_landesregeln vorhanden	LIVE
AE 20261003000000 camt_buchungsdublette	Index uq_zahlungseingaenge_org_buchungshash EXISTIERT NICHT	PENDING
CM 20260525 / 20260824 (3 Migrationen)	analytics_events 200, newsletter_campaigns 200, visit_logs 401	LIVE
CM 20260824 pricing_schema	protect_pricing.risk_level u.a. → 42703, Spalte fehlt	PENDING

ChairMatch supabase/migrations/_OFFEN_2026-08-24.sql ist veraltet — die drei darin gebündelten Migrationen sind live. Die Datei zeigt erledigte Arbeit als offen.

5 · Gefundene und behobene Bugs

Alle sieben Befunde: IMPLEMENTIERT + GETESTET + CI-GRÜN + DEPLOYED.

Schwere	Befund	Wirkung
P1	Cron-Bearer fail-OPEN in /api/cron/drip und /api/cron/indexnow — kein Null-Riegel	Ohne gesetztes CRON_SECRET lautete der Vergleichswert wörtlich "Bearer undefined". Jeder Fremde konnte beide Läufe auslösen. 5 von 7 Routen hatten den Riegel — eine kopierte Prüfung ist gedriftet
P1	Pfad-Traversal im DTA-Rückläufer-Upload	Ein Dateiname mit ../ verlässt die Organisationsablage. Einzige der 10 Upload-Routen ohne Bereinigung
P1	CAMT-Dublettensperre nur auf Dateiebene	Banken schneiden Auszüge überlappend; der Dateihash ist dann ein anderer. Jede bereits verbuchte Zahlung wurde ein zweites Mal angelegt, gematcht und einer Rechnung zugeordnet
P2	DATEV-CSV: escapeText kürzte NACH dem Verdoppeln der Anführungszeichen	Ein Paar auf der Grenze 60 wurde zerschnitten; das übrige Zeichen beendet das Feld und verschiebt die Buchungszeile. Auslöser: ein Klientenname aus dem Kundenformular
P2	DATEV-CSV ohne Formel-Riegel; CAMT/DTA ohne Größenriegel; getPublicUrl auf privatem Bucket	CSV-Injection in KOST1/KOST2/Belegnummer; Datei vollständig im Serverless-Speicher vor der Bucket-Ablehnung; persistierter Beleg-Link, der nie auflöst

Live-Gegenprobe zum Cron-Fix: 30 Anfragen gegen alltagsengel.care mit "Bearer undefined" / "Bearer " / "Bearer falsch" / ohne Header → alle 401. Der CAMT-Fix hat zwei Hälften: die App-Prüfung ist live, die DB-Sperre nicht.

6 · Offene Punkte

P0 — keine.

Die drei Anwarter wurden geprüft und abgeräumt: RLS 308/308, anon-Schreibrechte 0, org_fence 244/244 RESTRICTIVE.

P1

- CAMT-Dublettensperre-Migration nicht eingespielt — kein DDL-Zugang. Bis dahin schützt nur die App-Prüfung, nicht gegen parallele Importläufe.
- CAMT-Pfad in Produktion nie gelaufen (camt_imports = 0). Der erste Echtlauf gehört begleitet.
- Zustellung live unbewiesen (invoice_email_log = 0, notification_delivery_log = 0).
- 28 kritische Module weiterhin ohne Tests (Bestand aus Phase 4.5).
- ChairMatch pricing_schema nicht eingespielt — /admin/pricing ist ohne die Spalten funktionsunfähig und meldet das seit 30622cd ehrlich.

P2 / P3 — live nachgeprüft

- BESTÄTIGT P2-a: 5 Buckets ohne Größenlimit UND ohne MIME-Allowlist (abrechnung, documents, mis-documents, service-proofs, verordnungen); kim-attachments zusätzlich ohne MIME.
- BESTÄTIGT P2-b: 3 dta-dateien-Storage-Policies prüfen per EXISTS(SELECT 1 FROM profiles ...) statt is_admin() und sind org-blind — realer horizontaler Pfad zwischen Admins verschiedener Organisationen.
- ZURÜCKGENOMMEN P2-d: Der Vorbericht meldete state_waitlist INSERT ohne WITH CHECK. Live trägt die Policy state_waitlist_insert ein vollständiges WITH CHECK (E-Mail-Format, notified_at IS NULL, user_id = auth.uid(), state_flag = true). Befund gestrichen.
- Offen: P2-c (7 Tabellen ohne org_fence, Tiefenschutz), P2-e (lange signierte URLs), P2-f (keine Magic-Byte-/AV-Prüfung), P3-a (lib/file-upload-validation.ts ohne Aufrufer), P3-b (sanitizeFileName in 6 Kopien — genau diese Vervielfältigung hat den Traversal verursacht).

7 · Externe Blocker

Blocker	Ort	Stand
CRON_SECRET fehlt	GitHub Repo Secrets	GELÖST — gesetzt 24.08. 10:23:35Z
RECHNUNGSVERSAND_AUTOMATISCH	Vercel Projekt-Env	offen (nicht direkt lesbar)
MAHNVERSAND_AUTOMATISCH	Vercel Projekt-Env	offen (nicht direkt lesbar)
AE camt_buchungsdublette	Supabase-SQL-Editor	offen
CM pricing_schema	Supabase-SQL-Editor	offen
CM Preise (Stufen, Beträge)	Geschäftsentscheidung	offen — nicht aus Code ratbar
§45a-Bescheid Hessen, Kassentarife	Behörde / Kassen	offen (Bestand)

Zu den Vercel-Flags: die Projekt-Env ist aus dieser Session nicht lesbar. Messbar ist nur, dass invoice_email_log und notification_delivery_log live auf 0 stehen — das ist mit "Automatik aus" vereinbar, aber kein Beweis für den Flag-Zustand. Bewusst als unverifiziert geführt.

8 · Security · Resend / Retry · CAMT

Security — keine offene KRITISCH- oder P0-Lücke.

Gegen Produktion bestätigt: RLS 308/308 · anon-Schreibrechte 0 · anon liest 331 Relationen, davon 6 bewusst öffentlich und 0 ungewollte Zeilen · 0 SECURITY-DEFINER-Funktionen für anon ausführbar · org_fence 244/244 RESTRICTIVE · 13 Buckets alle privat · alle 44 service-role-Fundstellen serverseitig · Webhook-Signaturen fail-closed. Broken Access Control: horizontal kein Weg gefunden — Ausnahme P2-b. Vertikal kein Weg gefunden. IDOR: ID-Routen filtern über auth.ctx.organizationId, nicht über die Pfad-ID.

Resend — funktionsfähig, aber ungenutzt.

Key gültig (HTTP 200), Domain alltagsengel.care status=verified, DKIM/SPF stehen, Region eu-west-1. Gemessen: invoice_email_log = 0. Der Weg trägt, es geht nur nichts darüber, solange die zwei Vercel-Flags nicht gesetzt sind.

Retry — jetzt scharf.

dunning_email_queue trägt live versuche, letzter_versuch_am, naechster_versuch_ab, den Endzustand aufgegeben und beide Retry-Indexe. Mit dem gesetzten CRON_SECRET feuert der Workflow "Zustellung Retry" tatsächlich — drei erfolgreiche Läufe belegt (10:45, 10:46, 11:14). Das ist die eigentliche Verbesserung dieser Phase: der Wiederholungsweg war gebaut, aber nie gestartet.

CAMT — NOT_READY für den unbegleiteten Produktivbetrieb.

Grün: Parser gehärtet (Rücklastschrift, Sammelbuchung, PDNG, SHA-256, fail-closed statt 0,00 €), App-Dublettensperre deployed, 20-MB-Riegel, E2E-Suite über echtes Postgres (961 Z.). Rot: DB-seitige Dublettensperre PENDING und kein einziger Echtlauf. Beides hängt zusammen — ohne UNIQUE-Index sind parallele Importläufe ungesichert, ohne Echtlauf gibt es keinen Beleg, dass ein reales Bankformat den Parser passiert. READY wird daraus, wenn die Migration eingespielt ist UND ein erster begleiteter Import gelaufen ist.

9 · GO / NO-GO

Projekt	CODE	TEST	CI	LIVE	Urteil
ALLTAGSENGEL	OK	5627 grün	success	health 200, version=HEAD	CONDITIONAL GO
CHAIRMATCH	OK	487 grün	success	HTTP 200, Schema deckt sich	CONDITIONAL GO

Kein NO-GO, weil kein P0 offen ist und der ausgelieferte Stand live nachweisbar der geprüfte Stand ist. Kein volles GO, weil die Geldpfade zwar getestet, aber in Produktion leer sind — getestet ist nicht gelaufen.

Bedingungen Alltagsengel

- camt_buchungsdublette einspielen — VOR dem ersten CAMT-Import, nicht danach.
- Ersten CAMT-Import begleitet fahren, Ergebnis gegen zahlungseingänge und payments gegenprüfen.
- Die zwei Versand-Flags in Vercel bewusst setzen — erst dann geht Post an Kunden raus.
- P2-b schliessen, bevor ein zweiter Mandant DTA-Dateien ablegt. Solange nur eine Organisation produktiv arbeitet, ist der Pfad theoretisch.
- Bucket-Limits für die 5 Buckets aus P2-a setzen (20 MB + MIME-Allowlist).

Bedingungen ChairMatch

- pricing_schema einspielen; Preise als Geschäftsentscheidung über das Seed-Template setzen — die Beträge aus 20260310 sind Entwurfswerte und gelten nicht.
- _OFFEN_2026-08-24.sql aufräumen; Service-Role-Key bleibt tot (Bestand).

10 · Nächste empfohlene Phase — Erstbetrieb der Geldpfade, begleitet

Der Befund in einem Satz: das System ist gebaut, geprüft und ausgerollt — aber die Pfade, an denen Geld hängt, sind leer (payments 0, camt_imports 0, invoice_email_log 0). Weitere Testarbeit an diesen Modulen bringt jetzt weniger als ein einziger echter Durchlauf. Reihenfolge: (1) beide Migrationen einspielen, additiv und idempotent, ohne DROP · (2) ein echter Rechnungsversand mit invoice_email_log als Gegenprobe, danach erst das Flag umlegen · (3) ein echter CAMT-Import einer realen Bankdatei, begleitet · (4) P2-b schliessen · (5) erst danach die 28 ungetesteten Module. Was NICHT getan werden sollte: weitere Härtung an CAMT oder am Versandweg ohne einen Echtlauf dazwischen. Beide Wege sind dreimal verschärft worden, ohne dass je Produktionsdaten durchgelaufen sind — jede weitere Runde härtet gegen Annahmen statt gegen Beobachtungen.